Procédure Gestion des comptes à privilèges

Domaine :	Sécurité des systèmes d'information
Macro Processus :	Gouvernance des accès
Processus :	Gestion des comptes à privilèges
Référence :	SEC-02
Version :	1.2

Responsables du document

	Nom	Entité	Date
Rédacteur(s)	Sofia Mekouar (Consultante Organisation)	DTPO	02/01/2026
Vérificateur(s)	Ilham Tazi (Responsable de la Sécurité des Systèmes d'Information (RSSI))	DSSI	22/01/2026
	Meryem Alaoui (Responsable Gouvernance des Accès)	DSSI	22/01/2026
	Reda Cherkaoui (Responsable des Opérations de Sécurité)	DSSI	22/01/2026
	Nadia Berrada (Responsable Infrastructures et Cloud)	DSI	22/01/2026
Approbateur(s)	Karim Benjelloun (Directeur des Systèmes d'Information)	DSI	06/02/2026
	Fouad Sebti (Responsable Contrôle Permanent)	CP	06/02/2026
	Najat Belkadi (Directrice Transformation, Processus et Organisation)	DTPO	06/02/2026

Propriétaire de la procédure : Ilham Tazi (Responsable de la Sécurité des Systèmes d'Information (RSSI)).

Historique des révisions

Emetteur	Description	Demande de révision	Version	Approbation
Sofia Mekouar	Création de la procédure (projet PRJ-IAM-2025)		1.0	01/12/2025
Sofia Mekouar	Ajout des comptes d'urgence	DR-2026-19	1.2	16/02/2026

Généralités

Objet

Cette procédure encadre la création, l'usage, la surveillance et le retrait des comptes à privilèges d'Orizia (administrateurs, comptes techniques, comptes d'urgence). Elle limite le risque d'usage abusif des droits étendus.

Domaine d'application

Entrent dans le périmètre

- Comptes d'administration des systèmes, des bases de données et des applications
- Comptes techniques et comptes d'urgence

Sont exclus du périmètre

- Comptes utilisateurs standard, traités selon SEC-01

Références

- Politique de gestion des accès d'Orizia
- Procédure SEC-01
- Procédure amont SEC-01 – Gestion des habilitations et des accès applicatifs : Les comptes à privilèges complètent le circuit d'habilitation standard.
- Procédure aval SEC-03 – Gestion des incidents de sécurité : Toute utilisation anormale d'un compte à privilèges est traitée comme un incident de sécurité.
- Procédure complémentaire IT-02 – Gestion des changements informatiques : Les interventions à privilèges sur la production sont rattachées à un changement approuvé.
- Projet : PRJ-IAM-2025 – Mise en place de la gestion des identités et des habilitations (OriIAM, OriVault).

Définitions

- OriVault : Coffre-fort des comptes à privilèges.
- OriIAM : Outil de gestion des identités et des habilitations.
- RSSI : Responsable de la Sécurité des Systèmes d'Information.

Acteurs

Acteur	Direction / Entité	Rôle dans la procédure
Responsable de la Sécurité des Systèmes d'Information	DSSI	Autorise les comptes à privilèges
Responsable Gouvernance des Accès	DSSI	Tient l'inventaire des comptes à privilèges et pilote la revue
Responsable des Opérations de Sécurité	DSSI	Surveille l'usage des comptes via OriVault et OriSOC
Titulaire du compte à privilèges	DSI	Utilise le compte dans le cadre d'une intervention autorisée
Responsable Infrastructures et Cloud	DSI	Valide le besoin d'administration

Sommaire

Responsables du document
Historique des révisions
Généralités
Objet
Domaine d'application
Références
Définitions
Acteurs
Règles de gestion
Liste des contrôles
Logigramme
Commentaires du logigramme
Opérations
Annexes

Règles de gestion

I- Pré-requis

La réalisation de la procédure nécessite la disponibilité des éléments suivants :

- Compte nominatif dans OriIAM
- Formation obligatoire à l'usage des comptes à privilèges

II- Règles applicables

R1. Tout compte à privilèges est nominatif, sauf compte technique déclaré dans l'inventaire.

R2. Tout accès à un compte à privilèges passe par OriVault et est enregistré.

R3. Les mots de passe des comptes à privilèges sont renouvelés au maximum tous les 90 jours.

R4. Les comptes à privilèges sont revus chaque mois.

R5. Un compte d'urgence est scellé dans OriVault. Chaque utilisation est justifiée dans les 24 heures et revue par le RSSI.

R6. Toute utilisation anormale d'un compte à privilèges est transmise au Responsable des Opérations de Sécurité et traitée selon la procédure SEC-03.

R7. Un compte à privilèges est retiré dès que le besoin disparaît ou lors du départ ou de la mobilité du titulaire.

III- Exceptions et cas particuliers

- Un compte à privilèges accordé en urgence pour un incident P1 est régularisé sous 1 jour ouvré et retiré à la fin de l'incident.
- Les prestataires externes disposent d'un compte à privilèges limité à 30 jours renouvelables après nouvelle autorisation du RSSI.

IV- Sorties et archivage

- Sortie : Inventaire des comptes à privilèges à jour
- Sortie : Rapport de revue mensuelle
- Les journaux de sessions sont conservés 12 mois dans OriVault.

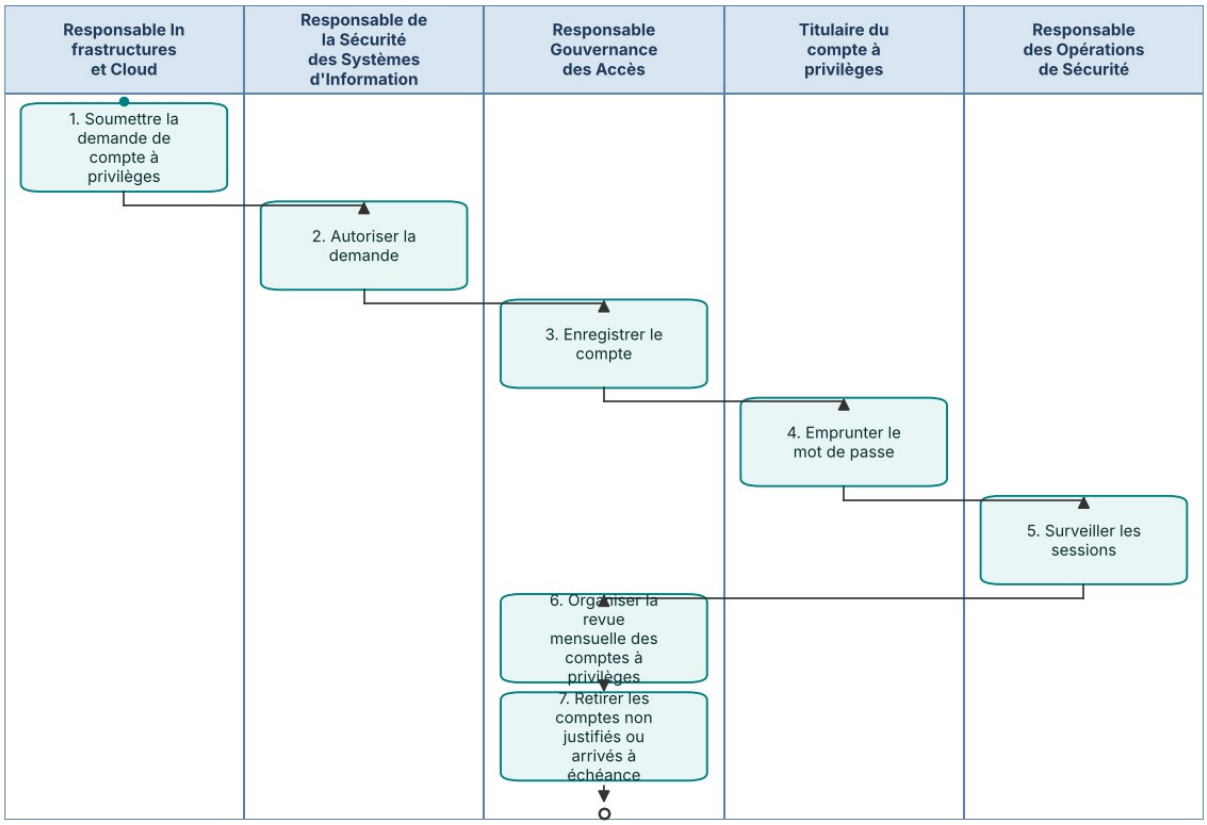
V- Indicateurs de suivi

Indicateur	Cible
Taux de comptes à privilèges revus	100 %
Nombre de comptes à privilèges sans titulaire identifié	0
Taux d'utilisations d'urgence justifiées dans les 24 heures	100 %

Liste des contrôles

N°	Contrôle	Responsable du contrôle	Fréquence
C1	Revue mensuelle de l'inventaire des comptes à privilèges	Responsable Gouvernance des Accès	Mensuelle
C2	Contrôle de la justification des sessions à privilèges sur échantillon	Contrôle Permanent	Trimestrielle
C3	Contrôle des utilisations de comptes d'urgence	Responsable de la Sécurité des Systèmes d'Information	À chaque utilisation

Logigramme



Commentaires du logigramme

Opérations

Temporisateur : Dès le besoin

Libellé de l'opération	Acteur
1. Soumettre la demande de compte à privilèges	**Responsable Infrastructures et Cloud**
Commentaires : Soumet la demande de compte à privilèges avec la justification du besoin. *Outil(s) : OrilAM. Délai : Dès le besoin.*	

Libellé de l'opération	Acteur
2. Autoriser la demande	**Responsable de la Sécurité des Systèmes d'Information**
Commentaires : Autorise la demande et fixe la durée de validité. *Outil(s) : OrilAM. Délai : 3 jours ouvrés.*	

Libellé de l'opération	Acteur
3. Enregistrer le compte	**Responsable Gouvernance des Accès**
Commentaires : Enregistre le compte dans OriVault et l'inscrit à l'inventaire. *Outil(s) : OriVault. Délai : 1 jour ouvré.*	

Libellé de l'opération	Acteur
4. Emprunter le mot de passe	**Titulaire du compte à privilèges**
Commentaires : Emprunte le mot de passe dans OriVault pour chaque intervention et renseigne le motif. *Outil(s) : OriVault. Délai : À chaque intervention.*	

Libellé de l'opération	Acteur
5. Surveiller les sessions	**Responsable des Opérations de Sécurité**
Commentaires : Surveille les sessions et examine les usages hors cadre. *Outil(s) : OriVault, OriSOC. Délai : Continue.*	

Libellé de l'opération	Acteur
6. Organiser la revue mensuelle des comptes à privilèges	**Responsable Gouvernance des Accès**
Commentaires : Organise la revue mensuelle des comptes à privilèges. *Outil(s) : OriVault. Délai : Mensuelle.*	

Libellé de l'opération	Acteur
7. Retirer les comptes non justifiés ou arrivés à échéance	**Responsable Gouvernance des Accès**
Commentaires : Retire les comptes non justifiés ou arrivés à échéance. *Outil(s) : OriVault, OriIAM. Délai : 2 jours ouvrés.*	

Annexes

Sans objet.